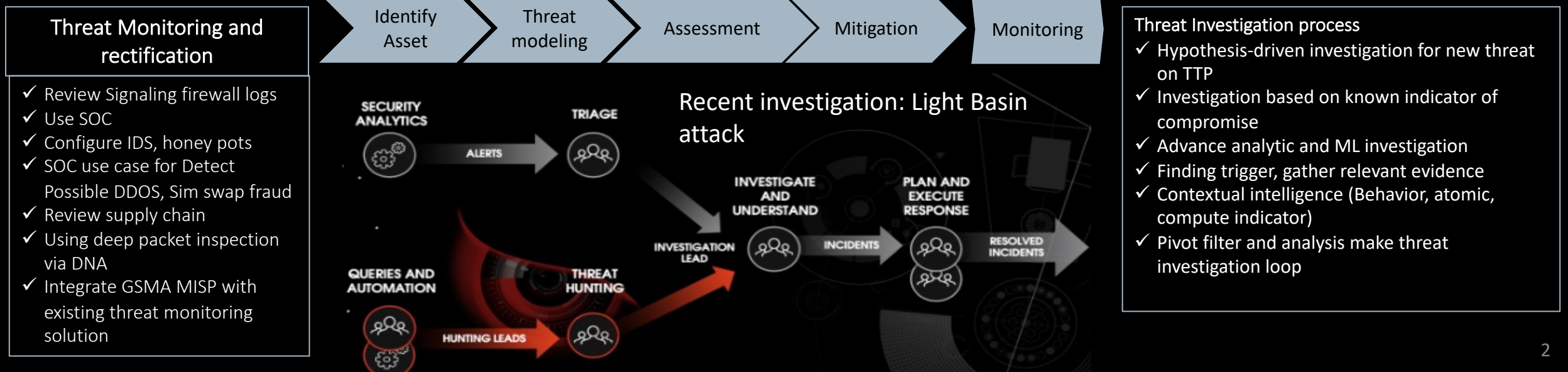
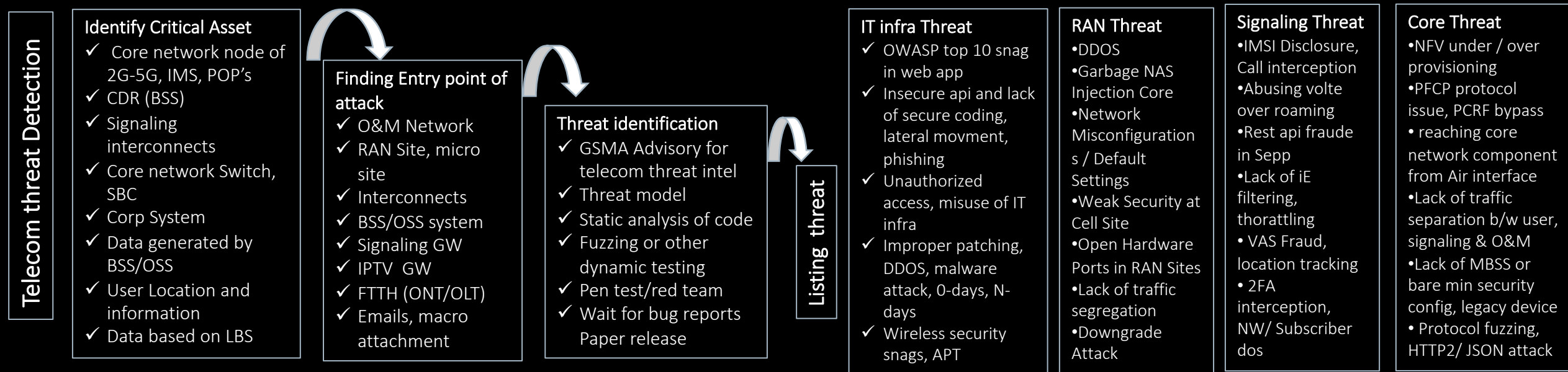




CASE STUDY – TELECOM THREAT DETECTION VIA STRIDE MAPPING

VINOD KUMAR SHRIMALI

Objective: What processes/steps should be followed to monitor, detect and investigate threats specifically for telecom products and IT infrastructure. Please also elaborate on rectification procedures according to your best knowledge.



Enumeration towards Core {Attack surface}

- Access Side (MS, RAN, microsite)
 - UE rotted device, srsue,
 - Unprotected RAN, unauthorized access to remote ran site
 - Femto Cell , finding ipsec key,
 - APN Fuzzing
 - OSS/BSS application exposure towards internet
 - MEC expose api
 - Nbiot end points
 - Public exposure of O&M interface
 - Supply chain vendor
 - Social engineering
 - NAS Device, CPE, internet gateway
 - Bitstream lack of segregation towards PPol routers

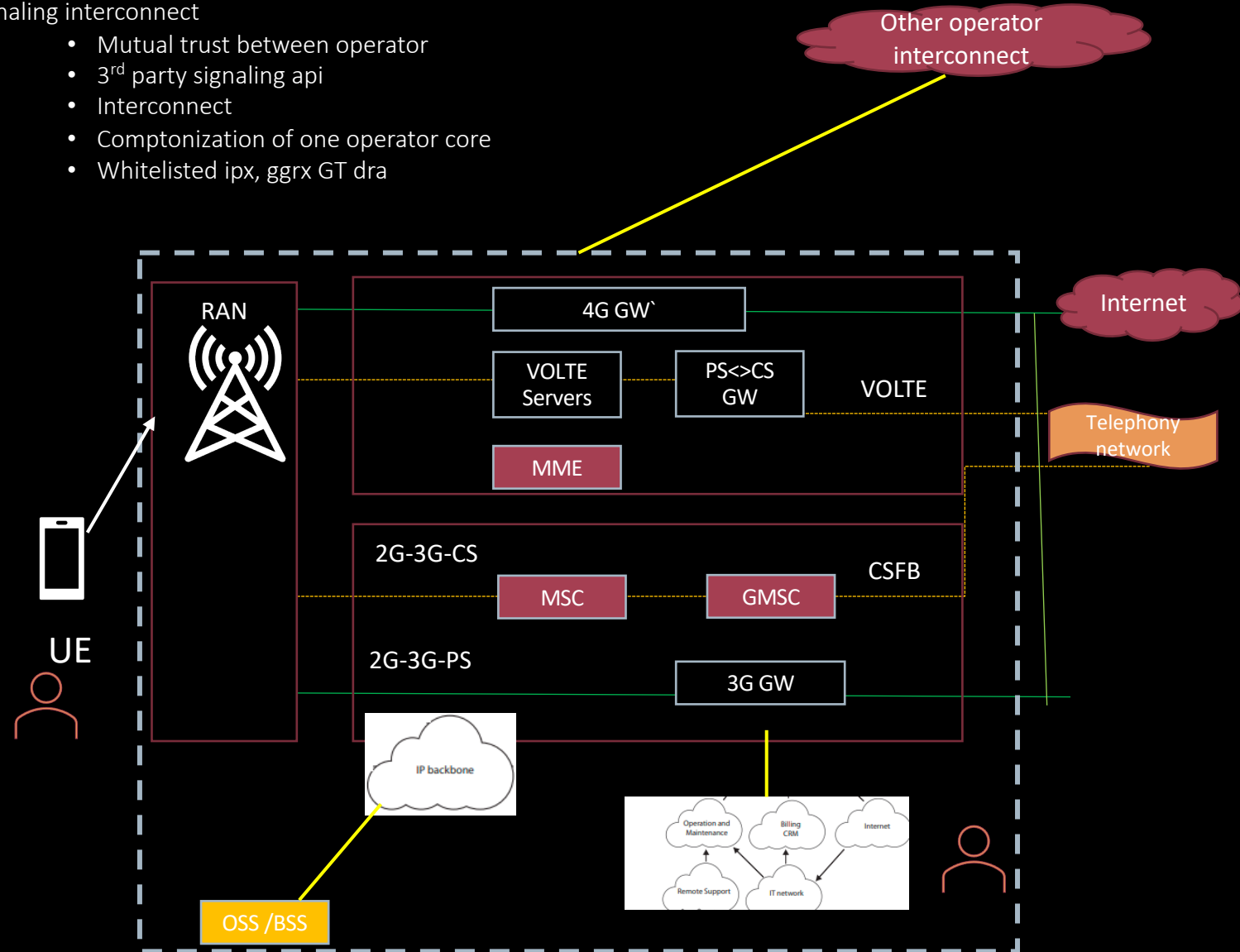
Case Study

- Scanning internal node from UE, modem, CPE
- Fuzzing different -2 Aprn ,
- Location change, connect to different radio provide {nokia, ericsson, Huawei}
- Using voice interface to scan send traffic towards internal node

Prevention

- Scanning internal node from UE, modem, CPE

- Signaling interconnect
 - Mutual trust between operator
 - 3rd party signaling api
 - Interconnect
 - Comptonization of one operator core
 - Whitelisted ipx, ggrx GT dra



Objective: Please elaborate on the STRIDE threat modelling and steps to implement and use this in any organization

Ways to Find Security Issues

- **Threat model**
- Static analysis of code
- Fuzzing or other dynamic testing
- Pen test/red team
- Wait for bug reports Paper release

- What are your most valuable assets?
- What are the potential threats to your device?
- What type of attack do you need to protect against?
- How severe are the threats?
- What counter-measures could you implement?
- What are your security requirements?
- How does your device meet your security requirement

Asset identification

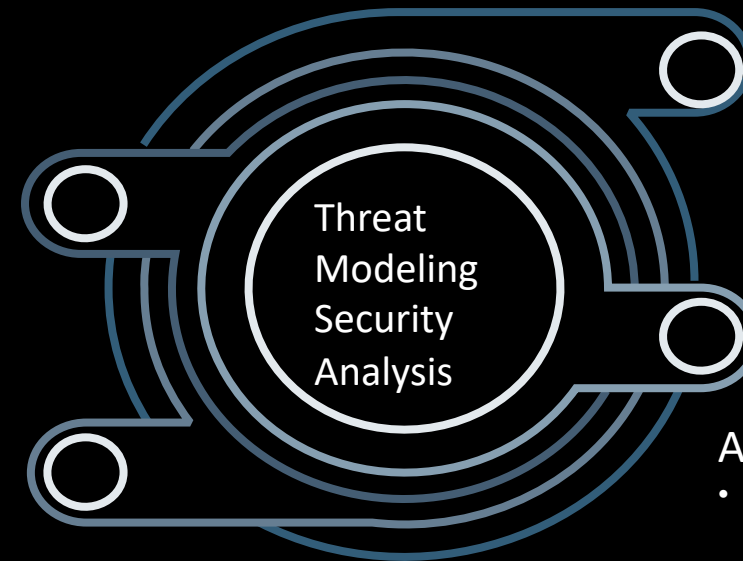
- Radio access network
- Core network
- Multi-access Edge Computing
- Physical infrastructure
- Virtualization
- UE, session, Api's, Application data

Identify Threat/ vuln & analysis

- Fake access node / abuse by rouge cloud service provide
- IMSI Cather, rouge MEC gateway
- Memory scraping in SDN, session hijacking
- Edge api exploitation or lateral movement in core NF
- Signaling fraud

Mitigation

- Zero-trust architecture approach
- Segmentation and isolation at network and application layers
- Policy-based security management
- Security controls automation Granular user access control
- Strong authentication and end point protection
- Certification and compliance of equipment and (virtual) network



Actor Definition

- Internal Actor: Rouge Admin, privileged insider, user(intentional/accidental)
- External operator: End user, external trusted operator, vendor, former authorized user, attacker, competitor,



STRIDE -5G Slicing

Tampering	Integrity	Modifying data on disk, memory, network, etc.,
-----------	-----------	--

- NFVO/ Hyper -V message tampering
- Rogue node between the Orchestrator and Host
- VNF image integrity
- Registration of malicious network function

Information Disclosure	Confidentiality	Providing information to someone who is not authorized
------------------------	-----------------	--

- Cross Slice secrete extraction
- Side Channel attack
- Lack of signaling & O&M traffic
- JSON based attack

Elevation of Privilege	Authorization	Allowing access to someone without proper authorization
------------------------	---------------	---

- UE Access to multiple slices with same auth
- Lack of authorization in slicing components
- Authentication relaxation for service/ latency



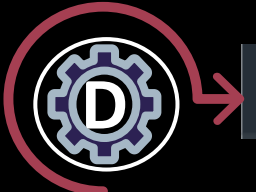
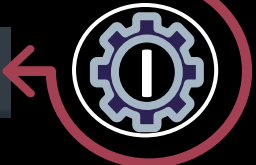
Spoofing	Authentication	Impersonating something or someone known and trusted.
----------	----------------	---

- MITM (man in middle)
- Impersonation of NSMF or host
- NSSAI Spoofing
- Impersonation of SMF
- Hyper-V compromised via api



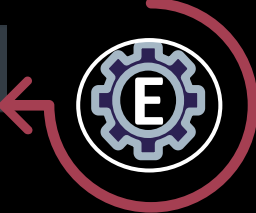
Repudiation	Non-repudiation	Claim to not be responsible for an action
-------------	-----------------	---

- Malicious activates from temp/unused vendor acc
- Spike in authentication traffic
- Slicing ID tampering
- Under/Over provisioning



D	Denial of Service (DoS)	Availability	Denying or obstructing access to resources required to provide service
---	-------------------------	--------------	--

- Exhaustion shared sec service
- DOS/DDOS
- Amplification
- Direct attack on NFV/ MANO



THANK YOU



Vinod Kumar Shrimali



@vinodkumarshrimalii

/



vshrimali@etisalat.ae